

Atea IRT monthly update

May edition (v1.0)
2026-05-13





General information

Introduction

The Atea IRT monthly update summarize threat activities worldwide and that IRT has seen the past months.

Company Confidentiality and Publicity Act

This document, with all its contents, shall not be displayed, copied or passed on to third parties without the written consent of Atea. Intellectual capital in this document belongs to Atea.

Content

Chapter 1: Atea IRT – Activity and Lessons Learned

Chapter 2: Atea IRT – Topics of Focus

Chapter 3: Threat activity worldwide

Chapter 4: Vulnerabilities

The background of the slide features a dark, futuristic environment with blue and green lighting. Several figures in tactical gear are visible, including one in the foreground looking through binoculars. A vertical green line is positioned on the left side of the slide.

Chapter 1:

Atea IRT Activity and Lessons Learned

Number of cases over time



1.1 Atea IRT case involvement

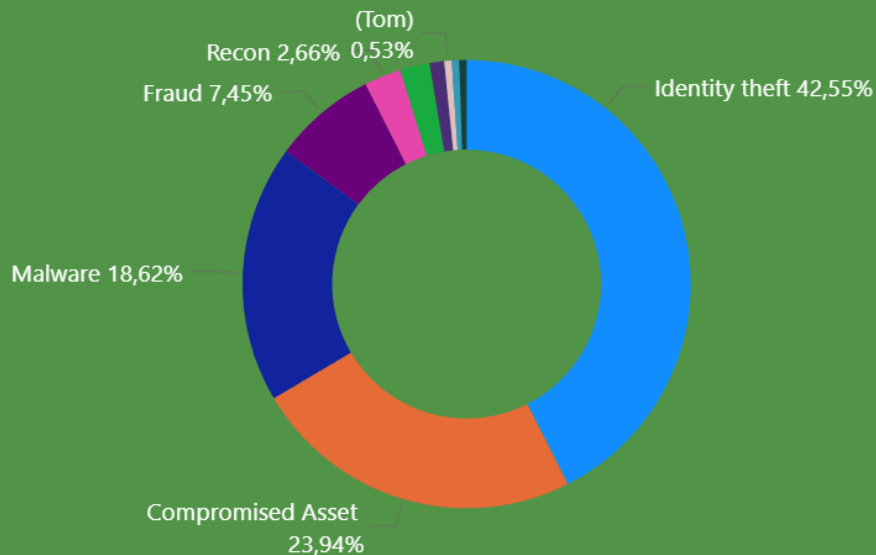
During April there's been an increase in engagements.

We've had cases with:

- Ransomware
- Malware / PUA
- Hunting
- AiTM

Over and over, we see employees of downloading malicious software believing it to be a useful tool. Googling and downloaded tool listed tools or even sponsored tools needs caution. This goes just as much for IT personnel.

Incident categories



In April Atea IRT participated in **Locked Shield 2026** together with the Norwegian Armed Forces, NSA, Icelandic NCSC, and several other private actors. Locked Shields is the **world's largest and most complex international live-fire cyber defence exercise**, hosted annually by the **NATO CCDCOE** since 2010.

A total of 4000 systems were attacked 8000 times in course of 2 weeks. The Norwegian/Icelandic team placed 5th of total 17 international teams. More information: <https://ccdcoe.org/locked-shields/>

1.2 Atea IRTs lessons learned

LESSONS FROM RECENT CASES

Another ransomware incidents handled.

The **lack of fundamental** cyber security hygiene continues to be the biggest worry as we soon are hit mid **2026**.

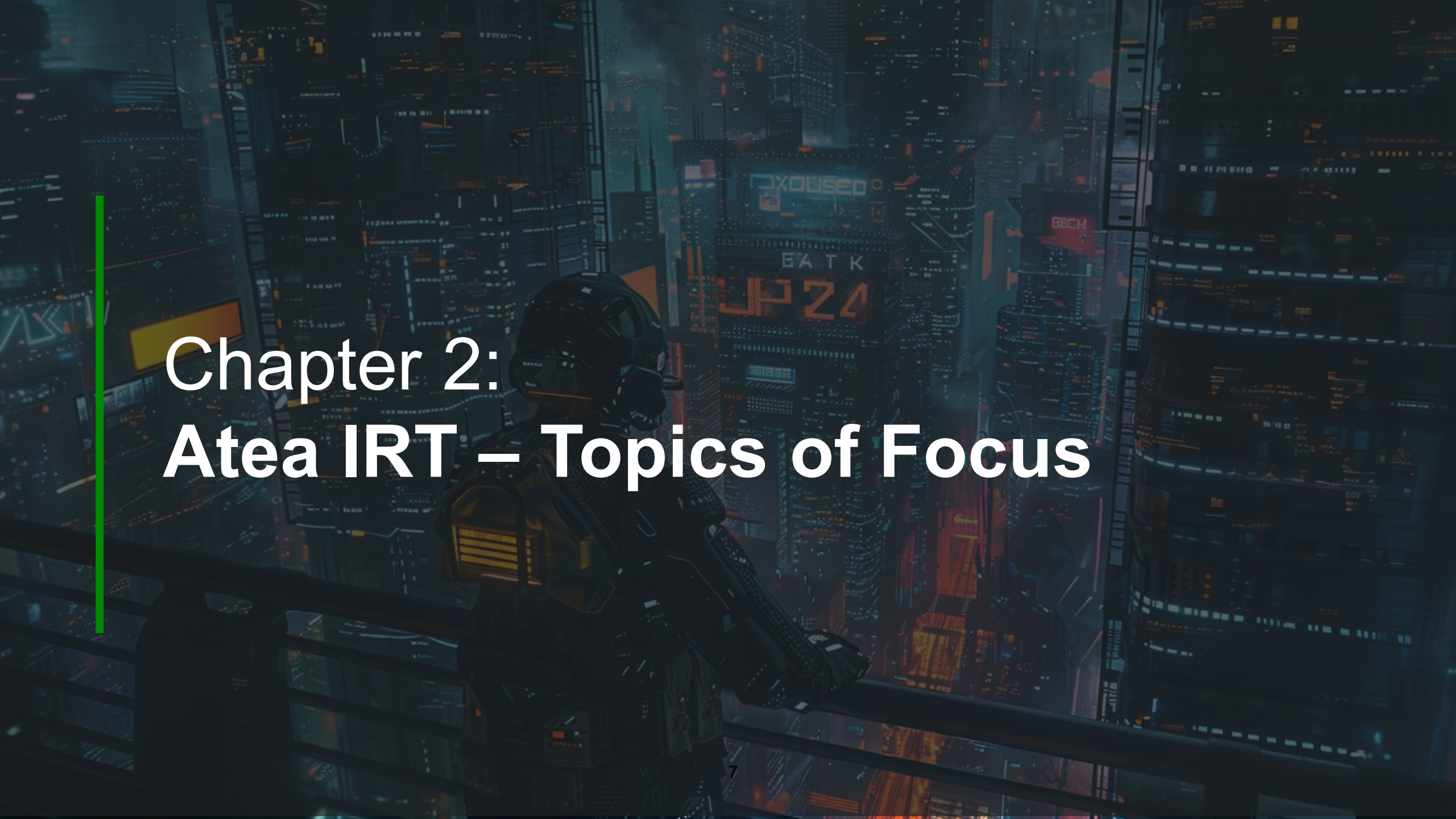
Encryption executed on the **hypervisor** is unfortunately normal in a ransomware. This complicates the incident greatly and to some extent limits our options for forensics. **Segmentation** and **access control** to hypervisors will make organisations more resilient.

We meet a lot of organisations that still need to disable **device-code authentication** and enable phish-resistant for their more privileged users.

This is the most effective security measures your organization could do to prevent against the phishing campaigns.

It's nothing new, but it shows that is needs to be repeated. Only just this month we responded to walk-in customer who had been subject to **AiTM phishing** and a subsequent invoice fraud. The attackers managed to defraud the company of **15000 EUR**.

Anubis is an emerging ransomware-as-a-service group recently seen in the Nordics.

A futuristic cityscape at night, viewed from a high vantage point. A person in a dark, tactical suit with a helmet and a yellow backpack is standing on a balcony, looking out over the city. The city is filled with tall buildings, glowing windows, and neon lights. A large digital display in the background shows the text "XOUSED", "EAT K", and "24". A vertical green line is on the left side of the image.

Chapter 2: Atea IRT – Topics of Focus

2.1 Certificate updates

Certificate duration is falling.

Fewer organization offer TLS certificated as well and there are no Nordic Certificate Authorities that offer TLS certificates since October 2025.

For a list over certificate authorities within EU/EIDAS see [here](#)

- Now 398 days apply until 15 March 2026
- From 15 March 2026, 200 days apply
- From 15 March 2027, 100 days apply
- From 15 March 2029, 47 days apply

Automation of certificate renewal process will be necessary.





Chapter 3: Threat activity worldwide

3.1 From the news

Alert galore – Microsoft Defender wrongly flags DigiCert certs as malicious

Following an incident where [DigiCert was breached by a malicious actor](#), Microsoft flagged multiple DigiCert certificates as malicious on 03.05.26. All though DigiCert had already revoked 60 certificates following the incident, the certificates flagged by Microsoft was not affected by the breach. [This caused a flood of false positives flagged as “Trojan:Win32/Cerdigent.A!dha”](#).

Microsoft was able to release the certificates from quarantine on the affected computers the same day.

Ransomware against Swedish municipalities Dorotea, Vilhelmina and Åsele

In early April, the municipalities was a [victim of a ransomware attack](#). All services for all the municipalities was down, including internet service for the residents and businesses of the area.

Public data breach from Fredrikstad Kommune

A post on a leak forum claimed to have hacked the Norwegian municipality Fredrikstad Kommune and posted employee data that seemed to come from Active Directory. After some investigation Fredrikstad Kommune [reported](#) that the data set was lifted from their “search for employee”-service on their public webpage. The service had a weakness that allowed the attacker to lift more information then was originally intended.

This shows the importance of securing any public facing APIs and services.



3.2 This is why we don't store password in browsers

A Norwegian researcher discovered that Edge unlocks all username and passwords stored in Edge at the time the user logs in and remains as plaintext in memory. This is perfect for adversaries that run clickfix campaigns.

Even though Edge is the only browser that do this as a “feature” other browsers have their own challenges regarding safe keeping of passwords.

Only valid solution is to use a good password vault, not embedded with the browser.

```
Administrator: Command Prompt

C:\temp>whoami
nsc\pparker

C:\temp>EdgeSavedPasswordsDumper.exe
Fetching browser processes: Done.

Scanning process PID: 6808      Name: msedge.exe      Owner: tstark
tony.stark : Ir0nman! @notarealcompany.com

Scanning process PID: 5408      Name: msedge.exe      Owner: maryjane
mary.jane.watson : ILovePeterParker! @notarealcompany.com

Total matches found across all processes: 2. 2 shown.

C:\temp>
```



Chapter 4: Vulnerabilities

Misc vulnerabilities [1/2]

Copy.Fail & DirtyFrag

Several vulnerabilities have been found in Linux. Some of them affects Linux distributions all the way back to 2017 and, as of writing, some do not have any patch for released.

Exploitation code exists.

Mitigating this is done by removing module from the kernel until you can patch/patch is released.

Mitigations strategies and more details can be found on the relevant blogs.

Copy.Fail (<https://copy.fail>)

CVE-2026-31431 – reliable and portable page-cache corruption from unprivileged userspace vulnerability.

Dirty Frag (<https://github.com/V4bel/dirtyfrag>)

CVE-2026-43284: xfrm-ESP Page-Cache Write vulnerability

CVE-2026-43500: RxRPC Page-Cache Write vulnerability

Notably, these are Local Privilege Escalations and needs to be chained together with other methods of initial foothold.



Misc vulnerabilities [2/2]

ArcaneDoor and FIRESTARTER

“According to the update, the ArcaneDoor threat actor has developed a previously unknown persistence mechanism that is preserved across upgrading to the fixed releases that were published in September 2025.

FIRESTARTER is a malicious backdoor implanted by UAT-4356 that allows remote access and control to execute arbitrary code inside the LINA process, a core component of Cisco’s ASA and FTD appliances running FXOS.”

A previous unknown backdoor, dubbed FIRESTARTER, has uncovered, following the exploitation of CVE-2025-20333 and CVE-2025-20362.

The backdoor hooks into legitime WebVPN functionality and listens for specially crafted packets with magic bytes, which upon activation executes a payload on the device.

The backdoor is stealthy and will remove evidence of itself after execution, and will write temporary files on a reboot signals, allowing it to maintain persistence over graceful reboots.

This affects Firepower series, ASA 5500-X series and Secure Firewall series.

See advisory for specifics, detection and mitigation:

<https://sec.cloudapps.cisco.com/security/center/content/CiscoSecurityAdvisory/cisco-sa-asaftd-persist-CISAED25-03>



4.1 Microsoft Patch Tuesday

4.1.1 Exploited in the wild

None

4.1.2 Publicly disclosed

None

4.1.3 Critical patches

CVE-2026-41089 – 9.8 – Windows Netlogon Remote Code Execution Vulnerability

A network request to a domain controller is all it takes to run code on the domain controller without logging in.

CVE-2026-41096 – 9.8 – Windows DNS Client Remote Code Execution Vulnerability

A malicious DNS response may corrupt memory on the DNS client that can lead to remote code execution.

4.1.4 Noteworthy patches

CVE-2026-40415 – 8.1 – Windows TCP/IP Remote Code Execution Vulnerability

An attacker could exploit this vulnerability by sending specially crafted malicious traffic to a vulnerable server.

CVE-2026-40361 – 8.4 – Microsoft Word Remote Code Execution Vulnerability (And also Outlook)

Zero-click vulnerability in Word and Outlook resulting in RCE when previewing or reading emails.

4.1.5 Noteworthy patches (requires manual intervention)

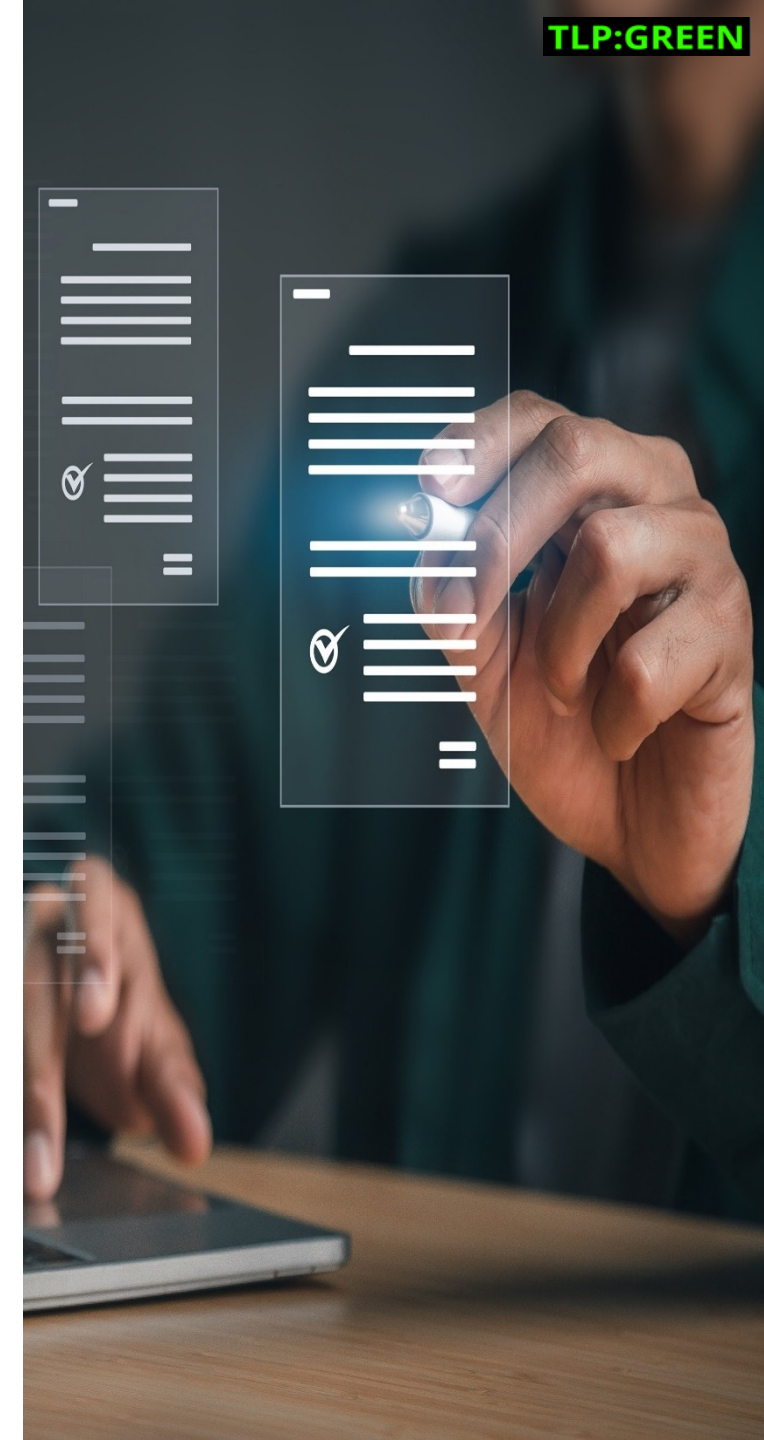
CVE-2026-42823 – 9.9 – Azure Logic Apps Elevation of Privilege Vulnerability

Check Azure Service Health notification to see if your organization is affected. Follow the mitigation in the notification.

CVE-2026-40370 – 8.8 – SQL Server Remote Code Execution Vulnerability

External control of file name or path in SQL Server allows an authorized attacker to execute code over a network.

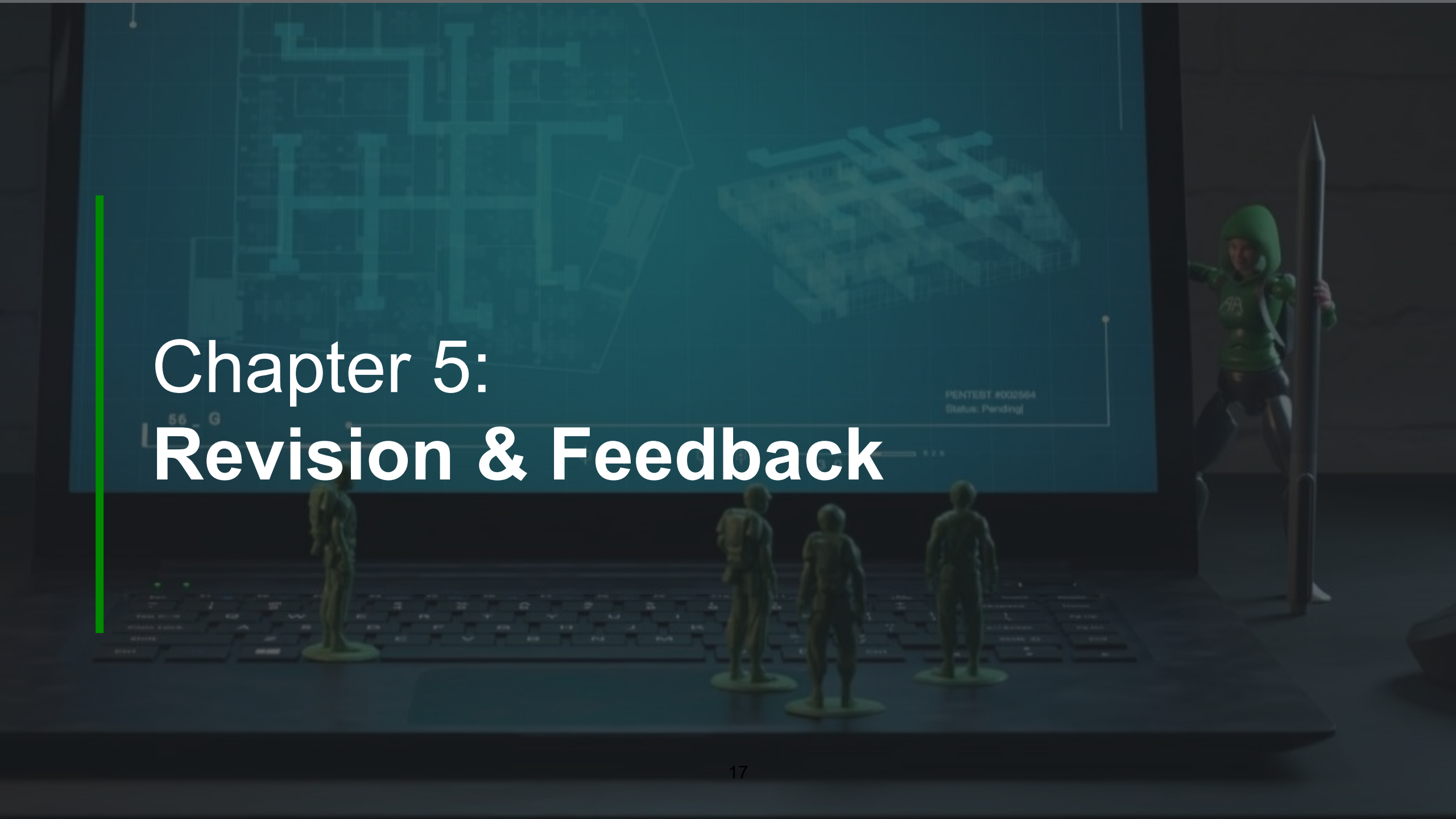
Check your version and apply correct patch



4.2 Vulnerabilities

ATEA IRT WOULD LIKE TO HIGHLIGHT THE FOLLOWING VULNERABILITIES

Date	Vendor	CVSS 3.0	CVSS 4.0	Patch exists	CVE	Description	Link
04.05.2026	Apache	8.8		Yes	CVE-2026-23918	Double Free and possible RCE vulnerability in Apache HTTP Server with the HTTP/2 protocol.	Website
06.05.2026	Palo Alto		9.3	No	CVE-2026-0300	Buffer overflow in Captive Portal (User-ID Auth portal) allows unauth attackers to get RCE and root on PA-series and VM-series firewalls	Website
08.05.2026	Linux	8.8		No	CVE-2026-43284, CVE-2026-43500	Dirty Frag: Universal Linux LPE - affects all distros since 2017, exploit code exists - remove module as mitigation	Website
12.05.2026	FortiNet	9.1		Yes	CVE-2026-44277	An Improper Access Control vulnerability [CWE-284] in FortiAuthenticator may allow an unauthenticated attacker to execute unauthorized code or commands via crafted requests.	Website
12.05.2026	FortiNet	9.1		Yes	CVE-2026-26083	A missing authorization vulnerability [CWE-862] in FortiSandbox, FortiSandbox Cloud and FortiSandbox PaaS WEB UI may allow an unauthenticated attacker to execute unauthorized code or commands via HTTP requests.	Website



Chapter 5: Revision & Feedback

5.1 Revision

Version	Revision Date	Description
1.0	2026-04-17	Atea IRT monthly update finalized

5.2 Feedback

We would love your feedback on both **CSA meetings** and **Atea IRT monthly update**. We also welcome all other feedback concerning Atea IRTs services.

Find the open and anonymous MS Form here:
www.ateairt.com/csafeedback